

Incident Report: MySQL Database Ransomware — CORP-DB-01

Report date: 2026-07-10 | Analyst: David Koschmann

Note on redaction: This report has been sanitized for public sharing. Internal hostnames, internal/external IP addresses, and attacker infrastructure (BTC addresses, onion email, ransom URLs, DATAIDs) have been replaced with placeholder values. Replaced values are consistent throughout the document (e.g. every reference to the original DB host now reads CORP-DB-01). Screenshots have been redacted to match.

1. Executive Summary

An internet-exposed MySQL server (CORP-DB-01) was accessed by multiple external IP addresses using the root account with no working password, starting 2026-07-09 14:12 (log-relative time). The attacker(s) enumerated production databases, dropped tables containing customer, payment, and credential data, and replaced them with a RECOVER_YOUR_DATA table containing a Bitcoin extortion demand.

The same drop-and-ransom pattern repeated four times over ~21 hours from different source IPs in the same /24 block. In parallel, an unrelated brute-force campaign against RDP/SMB on a separate Windows host (CORP-WKS-01) succeeded in authenticating as administrator twice; no follow-on activity from that account was found in available telemetry.

No file-level (ransomware/encryption) impact was observed on the Windows endpoint — this incident is a database-layer destructive extortion event, not host-based ransomware.

2. Incident Details

Field	Value
Detection date/time	Not determined from available logs (no SOC alert, ticket, or “first noticed” timestamp is present in the provided data; only raw telemetry timestamps are available)
Reporter	Not determined from available logs
Classification	Data destruction / extortion (DB-focused), via unauthorized/unauthenticated database access. Secondary, likely unrelated: RDP/SMB credential brute force with successful admin logon
Severity	High — confirmed loss/destruction of production data, extortion demand, likely exposure of a credentials table, and an unexplained successful admin logon on a second host
Affected assets	CORP-DB-01 (MySQL DB host, internal IP [INTERNAL-IP-REDACTED]) — primary; CORP-WKS-01 (Windows front-end host, user jdoe) — secondary/unconfirmed impact
Affected data	Databases corp_prod_db (tables: customers, orders, payments, credentials), sakila (sample/demo schema, includes staff_list), world (sample/demo schema)

KQL — scope the affected host(s) and confirm no other assets touched by the same source IPs

```
DeviceInfo
| where DeviceName in ("CORP-WKS-01", "CORP-DB-01")
| project TimeGenerated, DeviceName, PublicIP, OSPlatform
```

Query Run query

```
1 DeviceInfo
2 | where DeviceName in ([REDACTED], [REDACTED])
3 | project TimeGenerated, DeviceName, PublicIP, OSPlatform
4
```

Results Query history Getting started

Timeline visualization

Export Show empty columns

Filters: Add filter

	TimeGenerated	DeviceName	PublicIP	OSPlatform
☐	> Jul 10, 2026 7:29:5...	[REDACTED]	([REDACTED])	Windows11
☐	> Jul 10, 2026 7:14:5...	[REDACTED]	([REDACTED])	Windows11
☐	> Jul 10, 2026 6:59:5...	[REDACTED]	([REDACTED])	Windows11
☐	> Jul 10, 2026 6:59:5...	[REDACTED]	([REDACTED])	Windows11
☐	> Jul 10, 2026 5:52:1...	[REDACTED]	([REDACTED])	Windows11
☐	> Jul 10, 2026 5:52:1...	[REDACTED]	([REDACTED])	Windows11
☐	> Jul 10, 2026 4:52:1...	[REDACTED]	([REDACTED])	Windows11
☐	> Jul 10, 2026 4:52:1...	[REDACTED]	([REDACTED])	Windows11
☐	> Jul 10, 2026 3:52:4...	[REDACTED]	([REDACTED])	Windows11

DeviceInfo query and results

3. Impact Assessment

Confidentiality: Attacker executed SELECT ... LIMIT 10 against credentials (columns: cred_id, customer_id, username, password, role, last_login) and payments (masked card data only — card_masked, card_last4, no full PAN observed) before deletion. This confirms the attacker viewed a sample of credential/payment data; full-table exfiltration (e.g., mysqldump, bulk export) is not determined from available logs — the query log shows only preview-style SELECTs, not bulk transfer.

Integrity/Availability: DROP TABLE/DROP DATABASE executed against corp_prod_db, sakila, and world, replaced with a single-row ransom note table. This is a full loss of table structure and data unless backups exist.

Scope: One MySQL host confirmed impacted. No evidence of lateral movement from the DB host to other database or application servers in the provided data.

Business impact: Loss of customer, order, payment-reference, and credential data for corp_prod_db pending restore. Regulatory/breach-notification exposure if credentials (usernames/passwords) or payment references are confirmed exfiltrated — requires DBA/legal review of table contents and backup state, not determined from these logs.

Query — post-breach file activity on CORP-WKS-01

```
DeviceFileEvents
| where DeviceName == "CORP-WKS-01"
```

```
| where FileName endswith ".csv" or FileName has "RECOVER_YOUR_DATA"
| project TimeGenerated, FolderPath, FileName, InitiatingProcessAccountName
| order by TimeGenerated asc
```

TimeGenerated	FolderPath	FileName	InitiatingProc
Jul 8, 2026 12:48:5...	C:\ProgramData\Microsoft\Windows\WER\Temp\WER.4cb4736-31fe-4229-9879-29b4994af029.tmp.csv	WER.4cb4736-31fe-4229-9879-29b4994af029.tmp.csv	system
Jul 8, 2026 1:37:09...	C:\ProgramData\Microsoft\Windows\WER\Temp\WER.2508204c-7a7a-416b-a55f-3a6df1917e7.tmp.csv	filterdriveraltitudes.csv	system
Jul 8, 2026 2:12:34...	C:\ProgramData\Microsoft\Windows\WER\Temp\WER.46be5c70-a61a-4214-bf55-0d9d47a4885d.tmp.csv	vmlookup.csv	system
Jul 8, 2026 2:12:55...	C:\ProgramData\Microsoft\Windows\WER\Temp\WER.46be5c70-a61a-4214-bf55-0d9d47a4885d.tmp.csv	WER.2508204c-7a7a-416b-a55f-3a6df1917e7.tmp.csv	system
Jul 8, 2026 2:13:36...	C:\ProgramData\Microsoft\Windows\WER\Temp\WER.46be5c70-a61a-4214-bf55-0d9d47a4885d.tmp.csv	WER.46be5c70-a61a-4214-bf55-0d9d47a4885d.tmp.csv	system
Jul 8, 2026 2:13:40...	C:\ProgramData\Microsoft\Windows\WER\Temp\WER.46be5c70-a61a-4214-bf55-0d9d47a4885d.tmp.csv	WER.f2ab47fd-5e90-40ad-9047-50d761cde74.tmp.csv	system
Jul 9, 2026 1:12:40...	C:\ProgramData\Microsoft\Windows Defender Advanced Threat Protection\Temp\CollectedData\2728f154-5c55-4627-bdbc-0a1f12798...	ScheduledTasks.csv	system
Jul 9, 2026 1:13:01...	C:\ProgramData\Microsoft\Windows Defender Advanced Threat Protection\Temp\CollectedData\2728f154-5c55-4627-bdbc-0a1f12798...	Processes.csv	system
Jul 9, 2026 1:13:02...	C:\ProgramData\Microsoft\Windows Defender Advanced Threat Protection\Temp\CollectedData\2728f154-5c55-4627-bdbc-0a1f12798...	Services.csv	system

DeviceFileEvents query and results

4. Indicators of Compromise

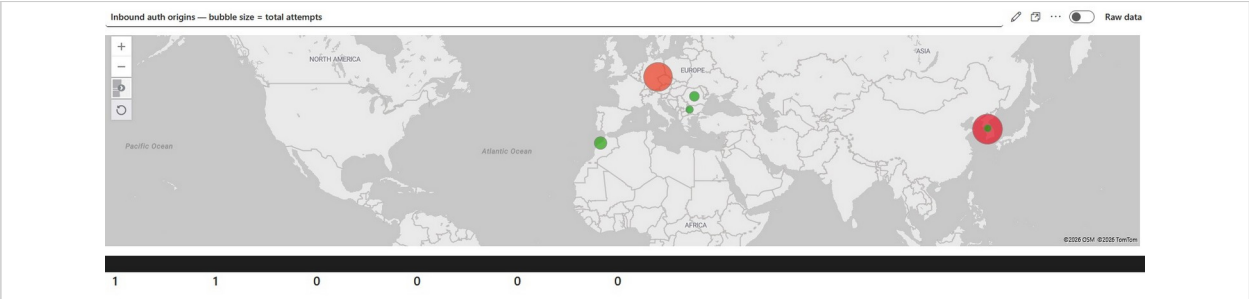
The IOC list provided in the tasking (BTC [REDACTED-BTC-ADDRESS-A], email [REDACTED-EMAIL-A], URL [REDACTED-URL-A], DATAID [REDACTED-DATAID-A]) was not found anywhere in the supplied logs. The actual IOCs recovered from the ransom note text and connection logs are below — flagging the discrepancy in case the provided IOC list belongs to a different incident/report template.

Type	Value	Source
BTC address	[REDACTED-BTC-ADDRESS-B]	MySQLAudit_CL_-_Queries (ransom note INSERT)
Contact email	[REDACTED-EMAIL-B]	MySQLAudit_CL_-_Queries (ransom note INSERT)
Reference URL	[REDACTED-URL-B]	MySQLAudit_CL_-_Queries (ransom note INSERT)
DATAID	[REDACTED-DATAID-B]	MySQLAudit_CL_-_Queries (ransom note INSERT)
Ransom table name	recover_your_data / RECOVER_YOUR_DATA	MySQLAudit_CL_-_Queries
Source IP (initial DB compromise)	[ATTACKER-IP-1]	MySQLAudit_CL_-_Auth_Logs
Source IPs (repeat DB wipe events)	[ATTACKER-IP-2], [ATTACKER-IP-3], [ATTACKER-IP-4] (same /24 as above)	MySQLAudit_CL_-_Auth_Logs
Source IPs (DB brute force/recon, no wipe observed)	[ATTACKER-IP-5] (914 events), [ATTACKER-IP-6], [ATTACKER-IP-10], [ATTACKER-IP-11], [ATTACKER-IP-12], [ATTACKER-IP-13]	MySQLAudit_CL_-_Auth_Logs
Source IP (RDP/SMB brute force, successful logon)	[ATTACKER-IP-7] (success), [ATTACKER-IP-8] (success)	DeviceLogonEvents

Type	Value	Source
Source IP (RDP/SMB brute force, failed only)	[ATTACKER-IP-9]	DeviceLogonEvents
Account abused	root (MySQL — accepted blank/no password), administrator (Windows)	Both audit sources

Query — inbound authentication origins (geo-mapped)

```
DeviceLogonEvents
| where Timestamp >= ago(3d)
| where DeviceName =~ "CORP-WKS-01"
| where RemoteIPType == "Public"
| where isnotempty(RemoteIP)
| where LogonType in ("Network", "RemoteInteractive")
| extend geo = geo_info_from_ip_address(RemoteIP)
| extend Latitude = toreal(geo.latitude), Longitude = toreal(geo.longitude),
    Country = tostring(geo.country), City = tostring(geo.city)
| where isnotempty(Latitude) and isnotempty(Longitude)
| summarize Attempts = count(),
    Successes = countif(ActionType == "LogonSuccess"),
    Failures = countif(ActionType == "LogonFailed"),
    TargetedDevices = dcount(DeviceName),
    Accounts = make_set(AccountName, 25)
    by RemoteIP, Country, City, Latitude, Longitude
| extend MapLabel = strcat(RemoteIP, " (", Country, ") - ", Successes, " success / ",
Attempts, " total")
| project Latitude, Longitude, MapLabel, Attempts, Successes, Failures,
TargetedDevices, RemoteIP, Country, City, Accounts
| order by Successes desc, Attempts desc
```



Inbound authentication origins geomap

5. Timeline

All times as recorded in TimeGenerated for each source (host-local, consistent across sources per raw UTC cross-check).

Time (2026)	Event	Source
Jul 8, 16:43 – Jul 10, 17:04	Repeated denied outbound flows from DB host [INTERNAL-IP-REDACTED] to port 123 (NTP), background noise — no C2/exfil indicators in the SIEM telemetry reviewed for this section	NTANetAnalytics

Time (2026)	Event	Source
Jul 9, 14:12:42	First failed then successful root connection from [ATTACKER-IP-1] with no password — initial DB access	MySQLAudit_CL_-Auth_Logs
Jul 9, 14:13–14:14	Enumeration and DROP TABLE of payments, orders, customers, credentials (corp_prod_db); staff_list (sakila); ransom note (DATAID [REDACTED-DATAID-B]) inserted	MySQLAudit_CL_-Queries
Jul 9, 16:00:25–16:00:32	RDP/SMB brute force against CORP-WKS-01 from [ATTACKER-IP-7]; LogonSuccess as administrator at 16:00:32, followed by more failed attempts from same IP	DeviceLogonEvents
Jul 9, 21:50:05–21:51:11	RDP/SMB brute force against CORP-WKS-01 from [ATTACKER-IP-9] (administrator/guest) — all failed	DeviceLogonEvents
Jul 9, 22:49 / 23:49	root brute force + success from [ATTACKER-IP-5] against MySQL (recon only, no drop observed)	MySQLAudit_CL_-Auth_Logs
Jul 10, 00:56:14	LogonSuccess as administrator on CORP-WKS-01 from [ATTACKER-IP-8]	DeviceLogonEvents
Jul 10, 05:26:11–13	Second wipe cycle: recover_your_data DB dropped/recreated with generic ransom text (BTC [REDACTED-BTC-ADDRESS-B]...) from [ATTACKER-IP-2]	MySQLAudit_CL_-Queries / Auth_Logs
Jul 10, 10:25:23–46	Third wipe cycle from [ATTACKER-IP-3]	MySQLAudit_CL_-Queries / Auth_Logs
Jul 10, 11:32–11:33:55	Fourth wipe cycle from [ATTACKER-IP-4]; also [ATTACKER-IP-6] root logon success (recon only) just prior	MySQLAudit_CL_-Queries / Auth_Logs
Jul 10, 16:52–17:05	Final recon session from [ATTACKER-IP-5] (SHOW TABLES, SELECT * FROM recover_your_data) — reading the ransom note back, no new drop	MySQLAudit_CL_-Queries

6. Root Cause / Attack Vector

Confirmed: The MySQL service on CORP-DB-01 was reachable from the internet and accepted root logons with no password (LogonFailure ... using password: NO immediately followed by LogonSuccess). This is the proximate cause of the database compromise — no exploit or credential theft was required.

Not determined from available logs: Whether the blank-password root account was a misconfiguration, a default left over from provisioning, or a deliberately disabled auth requirement (e.g., skip-grant-tables) — the audit log records the outcome, not the server configuration.

Not determined from available logs: How administrator credentials on CORP-WKS-01 were obtained by [ATTACKER-IP-7] and [ATTACKER-IP-8] (successful RDP/SMB logons followed brute-force attempts, consistent with password guessing succeeding, but no password-spray success pattern or credential-source evidence is present). No process, file, or registry activity tied to the administrator account was found in DeviceProcessEvents/DeviceFileEvents after these logons — this is a visibility gap, not evidence of no impact.

Not determined: Whether the Windows host compromise and the MySQL compromise are related (shared actor, shared infrastructure) or coincidental exposure of two weakly-secured services. No pivot (e.g., MySQL client tools launched from CORP-WKS-01, or outbound connections from that host to the attacker /24 range) was found in the DeviceNetworkEvents data reviewed for this section. A possible external connection was flagged separately in the Host DFIR Report (§4) from host-based triage artifacts collected directly from CORP-WKS-01; that finding has not

yet been cross-correlated against the SIEM network logs and should be treated as a lead pending validation, not a confirmed link.

KQL — check for a link between the two hosts / actor infrastructure

```
DeviceNetworkEvents
| where DeviceName == "CORP-WKS-01"
| where RemoteIP startswith "198.51.100." or RemoteIP in ("[ATTACKER-IP-5]", "[ATTACKER-IP-6]")
| project TimeGenerated, RemoteIP, RemotePort, InitiatingProcessFileName
```

1 DeviceNetworkEvents
2 | where DeviceName == "[REDACTED]";
3 | where RemoteIP startswith "[REDACTED]" or RemoteIP in [REDACTED]
4 | project TimeGenerated, RemoteIP, RemotePort, InitiatingProcessFileName
5

Results

Query history

Getting started

Export

Show empty columns

Filters:

Add filter

	TimeGenerated	RemoteIP	RemotePort	InitiatingProcessFil...
☐	> Jul 9, 2026 1:50:23... (0)	[REDACTED]	48735	
☐	> Jul 9, 2026 1:52:25... (0)	[REDACTED]	49121	
☐	> Jul 9, 2026 2:12:42... (0)	[REDACTED]	38794	mysqld.exe
☐	> Jul 9, 2026 6:28:40... (0)	[REDACTED]	58329	
☐	> Jul 9, 2026 7:28:00... (0)	[REDACTED]	49154	
☐	> Jul 9, 2026 7:43:44... (0)	[REDACTED]	36476	mysqld.exe
☐	> Jul 9, 2026 8:49:14... (0)	[REDACTED]	48438	mysqld.exe
☐	> Jul 9, 2026 9:09:46... (0)	[REDACTED]	53348	mysqld.exe
☐	> Jul 9, 2026 9:27:22... (0)	[REDACTED]	60064	mysqld.exe
☐	> Jul 10, 2026 5:25:5... (0)	[REDACTED]	37294	mysqld.exe
☐	> Jul 10, 2026 10:25... (0)	[REDACTED]	54994	mysqld.exe
☐	> Jul 10, 2026 11:32... (0)	[REDACTED]	58660	mysqld.exe

DeviceNetworkEvents query and results

7. Response Actions

Containment (recommended/urgent)

- Remove public internet exposure of MySQL on CORP-DB-01; restrict to a private subnet/VPN or explicit allow-list.
- Force a password reset on root and all MySQL accounts; disable remote root login entirely (skip-networking for root, or bind-address restriction).
- Reset administrator password on CORP-WKS-01; enable account lockout after N failed attempts; enforce MFA on RDP/remote access if not already present.
- Block identified attacker IPs at the perimeter/NSG.

Eradication

- Confirm no additional accounts, scheduled tasks, or stored procedures were created by the attacker (only RECOVER_YOUR_DATA artifacts observed in this dataset).

- Full malware/persistence sweep of CORP-WKS-01 given the confirmed successful admin logons with no visibility into post-logon actions, and given the unresolved C2 lead raised in the Host DFIR Report.

Recovery

- Restore corp_prod_db, sakila, world from last known-good backup predating 2026-07-09 14:12.
- Rotate all credentials stored in the credentials table (usernames/passwords were previewed by the attacker) regardless of exfiltration confirmation.
- Do not engage with or pay the extortion demand; report the BTC address/email to relevant fraud/threat-intel channels.

8. Evidence

- MySQLAudit_CL_-_Auth_Logs.csv — 1,048 rows, connection/auth events, source IPs, LogonSuccess/Failure.
- MySQLAudit_CL_-_Queries.csv — 961 rows, full query text including DROP/CREATE/ransom-note INSERT statements.
- DeviceLogonEvents.csv — 40 rows, RDP/SMB brute force and successful admin logons on CORP-WKS-01.
- DeviceProcessEvents.csv — 1,076 rows, reviewed for post-logon attacker activity; only legitimate user (jdoe) and Defender/system telemetry found.
- DeviceFileEvents.csv — 419 rows, reviewed for ransomware/file-encryption indicators; none found.
- DeviceRegistryEvents.csv — 11 rows, only legitimate Edge autolaunch and OS service entries.
- NTANetAnalytics.csv — 10 rows, denied outbound NTP traffic only; *no C2/exfil evidence within this dataset. A separate host-based triage collection (Host DFIR Report, §4) flagged a possible external connection on CORP-WKS-01 that does not appear here and has not yet been validated.*

Query — MySQL server logon attempts

```
// SQL Server
let MyDevice = "CORP-DB-01";
let MyTimeframe = todatetime("2026-07-09T03:45:12.3456789Z");
let FailedConnections =
MySQLAudit_CL
```

<pre> 1 // SQL Server 2 let MyDevice = ██████████ 3 let MyTimeFrame = todatetime("2026-07-09T03:45:12.3456789Z"); 4 let FailedConnections = 5 MySQLAudit_CL </pre>						
Results Query history Getting started						
Timeline visualization						
Export Show empty columns						
Filters: Add filter						
☐	TimeGenerated	DeviceName	Username	IpAddress	ActionType	RawData
☐	> Jul 10, 2026 5:37:3...	██████████	root	(v) localhost	LogonSuccess	2026-07-10T07:37:33.72...
☐	> Jul 10, 2026 5:37:1...	██████████	root	(v) localhost	LogonFailure	2026-07-10T07:37:18.84...
☐	> Jul 10, 2026 5:02:5...	██████████	root	(v) localhost	LogonSuccess	2026-07-10T07:02:50.11...
☐	> Jul 10, 2026 5:02:5...	██████████	root	(v) localhost	LogonSuccess	2026-07-10T07:02:50.18...
☐	> Jul 10, 2026 5:02:3...	██████████	root	(v) localhost	LogonFailure	2026-07-10T07:02:37.43...
☐	> Jul 10, 2026 5:02:1...	██████████	root	(v) localhost	LogonFailure	2026-07-10T07:02:16.59...
☐	> Jul 10, 2026 5:02:1...	██████████	root	(v) localhost	LogonFailure	2026-07-10T07:02:11.99...
☐	> Jul 10, 2026 4:52:1...	██████████	root	(v) ██████████	LogonSuccess	2026-07-10T06:52:19.76...
☐	> Jul 10, 2026 4:52:1...	██████████	sa	(v) ██████████	LogonFailure	2026-07-10T06:52:19.29...
☐	> Jul 10, 2026 4:52:1...	██████████	admin	(v) ██████████	LogonFailure	2026-07-10T06:52:18.71...
☐	> Jul 10, 2026 4:52:1...	██████████	root	(v) ██████████	LogonFailure	2026-07-10T06:52:18.15...

MySQL server logon attempts query and results

Query — filtering queries (DROP schema / ransom activity)

```

// Filtering Queries
let MyDevice = "CORP-DB-01";
let ServerVulnerableDateTime = todatetime("2026-07-09T03:45:12.3456789Z");
MySQLAudit_CL
| where TimeGenerated > ServerVulnerableDateTime
| where RawData has "Query"
| extend RawData = replace_string(RawData, "\t", " ")
| extend DeviceName = tostring(split(_ResourceId, "/")[-1])
| where DeviceName == MyDevice
| extend ActionType = "Query"
| extend Query = split(RawData, "Query")[1]
| project TimeGenerated, DeviceName, ActionType, Query, RawData
| order by TimeGenerated desc

```

```
33 // Filtering Queries
34 let MyDevice = [REDACTED]
35 let ServerVulnerableDateTime = todatetime("2026-07-09T03:45:12.3456789Z");
36 MySQLAudit_CL
37 | where TimeGenerated > ServerVulnerableDateTime
38 | where RawData has "Query"
39 | extend RawData = replace_string(RawData, "\t", " ")
40 | extend DeviceName = tostring(split(_ResourceId, "/")[-1])
41 | where DeviceName == MyDevice
42 | extend ActionType = "Query"
43 | extend Query = split(RawData, "Query")[1]
44 | project TimeGenerated, DeviceName, ActionType, Query, RawData
45 | order by TimeGenerated desc
46
```

Results

Query history

Getting started

Timeline visualization

Export

Show empty columns

1012 items

Search

Filters:

Add filter

☐	TimeGenerated	DeviceName	ActionType	Query	RawData
☐	> Jul 10, 2026 5:39:1...	[REDACTED]	Query	DROP schema recover_your_data	2026-07-10T07:39:19.482672Z 1059 Q...
☐	> Jul 10, 2026 5:39:1...	[REDACTED]	Query	DROP schema reverer_your_data	2026-07-10T07:39:10.189064Z 1059 Q...
☐	> Jul 10, 2026 5:38:5...	[REDACTED]	Query	DROP SCHEMA reverer_your_data	2026-07-10T07:38:55.233842Z 1059 Q...
☐	> Jul 10, 2026 5:38:2...	[REDACTED]	Query	SHOW FULL COLUMNS FROM [REDACTED]	2026-07-10T07:38:22.888026Z 1059 Q...
☐	> Jul 10, 2026 5:38:2...	[REDACTED]	Query	SHOW FULL TABLES FROM [REDACTED]	2026-07-10T07:38:22.877111Z 1056 Q...
☐	> Jul 10, 2026 5:38:2...	[REDACTED]	Query	SHOW FULL COLUMNS FROM [REDACTED]	2026-07-10T07:38:22.886589Z 1059 Q...

Filtering queries results, showing DROP schema and ransom activity

Query — virtual machine logons

```
// Virtual Machine Logons
let MyDevice = "CORP-WKS-01";
let ServerVulnerableDateTime = todatetime("2026-07-09T03:45:12.3456789Z");
DeviceLogonEvents
| where TimeGenerated > ServerVulnerableDateTime
| where DeviceName == MyDevice
| where AccountName in~ ("administrator", "guest")
| project TimeGenerated, RemoteIP, AccountName, DeviceName, ActionType, LogonType
```

Query Run query

```
48 // Virtual Machine Logons
49 let MyDevice = "CORP-WKS-01";
50 let ServerVulnerableDateTime = todatetime("2026-07-09T03:45:12.3456789Z");
51 DeviceLogonEvents
52 | where TimeGenerated > ServerVulnerableDateTime
53 | where DeviceName == MyDevice
54 | where AccountName in~ ("administrator", "guest")
55 | project TimeGenerated, RemoteIP, AccountName, DeviceName, ActionType, LogonType
56
```

Results Query history Getting started

Export Show empty columns

	TimeGenerated	RemoteIP	AccountName	DeviceName	ActionType	LogonType
☐	> Jul 9, 2026 9:50:57...	[REDACTED]	administrator	[REDACTED]	LogonFailed	Network
☐	> Jul 9, 2026 9:51:02...	[REDACTED]	administrator	[REDACTED]	LogonFailed	Network
☐	> Jul 9, 2026 9:51:07...	[REDACTED]	administrator	[REDACTED]	LogonFailed	Network
☐	> Jul 9, 2026 9:51:11...	[REDACTED]	administrator	[REDACTED]	LogonFailed	Network
☐	> Jul 10, 2026 12:56:...	[REDACTED]	administrator	[REDACTED]	LogonSuccess	Network
☐	> Jul 10, 2026 12:56:...	[REDACTED]	administrator	[REDACTED]	LogonSuccess	Network
☐	> Jul 9, 2026 4:00:25...	[REDACTED]	administrator	[REDACTED]	LogonFailed	Network
☐	> Jul 9, 2026 4:00:28...	[REDACTED]	administrator	[REDACTED]	LogonFailed	Network
☐	> Jul 9, 2026 4:00:32...	[REDACTED]	administrator	[REDACTED]	LogonSuccess	Network
☐	> Jul 9, 2026 4:00:32...	[REDACTED]	administrator	[REDACTED]	LogonSuccess	Network
☐	> Jul 9, 2026 4:02:44...	[REDACTED]	administrator	[REDACTED]	LogonFailed	Network
☐	> Jul 9, 2026 4:02:48...	[REDACTED]	administrator	[REDACTED]	LogonFailed	Network

Virtual machine logons query and results

9. Lessons Learned / Recommendations

- (Critical) Eliminate public internet exposure of database services; require VPN/bastion or private networking for all DB access. This is the direct root cause.
- (Critical) Enforce authentication on all database accounts — audit for blank/default passwords across all MySQL instances, not just this host.
- (High) Enable account lockout and MFA for RDP/remote Windows administration; investigate the two successful administrator logons for scope of compromise (gap in current telemetry).
- (High) Deploy DeviceNetworkEvents collection for the DB host tier — this incident could not be linked to outbound C2/exfiltration or to the Windows host compromise using the SIEM sources reviewed in this report due to missing network telemetry.
- (Medium) Verify and test backup/restore process for corp_prod_db; confirm backup cadence covers the gap since last clean state.
- (Medium) Add detection rule for DROP DATABASE/DROP TABLE and RECOVER_YOUR_DATA-pattern inserts in MySQL audit logs to catch this class of attack in real time going forward.
- **(High)** Reconcile the possible C2 connection to a trafficmanager.net domain raised in the Host DFIR Report (§4) against SIEM network flow logs (DeviceNetworkEvents, NTANetAnalytics) and

firewall/proxy logs. This finding currently rests on host-based triage artifacts alone and has not been corroborated — or ruled out — by the network telemetry reviewed for this report.

Host DFIR Report

1. Baseline Determination

The baseline is determined to be the “Pre-Breach” set (collected ~2026-07-09). The “Post-Breach” comparison set (collected ~2026-07-10) is used to identify indicators of unauthorized change. This analysis is based on a host-based triage collection from CORP-WKS-01 (Prefetch, service state, process list, live network connections at time of collection) rather than the centralized SIEM logs used in the main incident report above; where a finding here has not been corroborated in the SIEM data, that is noted explicitly rather than presented as confirmed.

2. Summary Verdict

Compromise Indicators Found: Yes

Confidence Level: High for host-based manipulation (database activity, ROBOCOPY staging, service-state changes); **Medium/Unconfirmed** for the Command-and-Control item specifically — it is not corroborated by the SIEM network flow logs reviewed in the main incident report (see §4 note below).

Justification: Evidence of active database manipulation, unauthorized staging of files via ROBOCOPY, and the modification of critical system service states (AarSvc, DcomLaunch) strongly indicates an active, manual intrusion rather than benign system churn. The additional network finding described in §4 is treated as a lead requiring validation rather than a confirmed indicator, pending correlation with firewall/proxy/NetFlow data.

3. Table of Notable Deltas

Category	Item	Change Type	Benign vs Suspicious	Evidence
Services	AarSvc	CHANGED	Suspicious	Baseline State: Running; Post-Breach: Stopped.
Processes	mysqld.exe	CHANGED	Suspicious	PID increment (baseline 1368 to post 4704) with high activity.
Execution	ROBOCOPY.EXE	ADDED	Suspicious	Found in post-breach PrefetchFilesList.txt.
Network	[C2-IP-REDACTED]	ADDED	Suspicious — unconfirmed	C2-like traffic to [REDACTED-DOMAIN].trafficmanager.net, observed in host-based ActiveNetConnections.txt only. <i>Not present in DeviceNetworkEvents or NTANetAnalytics reviewed for the main incident report — requires firewall/proxy log correlation before treating as confirmed C2.</i>

4. Prioritized List of Strongest Compromise Indicators (Mapped to ATT&CK)

- **Command and Control (TA0011) — unconfirmed:** Possible persistent connection to [REDACTED-DOMAIN].trafficmanager.net (IP [C2-IP-REDACTED]), observed only in host-based live-response artifacts (ActiveNetConnections.txt). This connection was not found in the DeviceNetworkEvents or NTANetAnalytics SIEM sources reviewed in the main incident report (Sections 6 and 8), which covered a narrower IP/time filter. Treat as an investigative lead pending correlation with firewall, proxy, or full-packet-capture logs — not yet a confirmed C2 channel.
- **Collection / Exfiltration (TA0009 / TA0010):** Repeated execution of ROBOCOPY.EXE to move files into a directory used for temporary staging.
- **Persistence / Defense Evasion (TA0003 / TA0005):** Manipulation of system service states and PID fluctuations in svchost.exe (hosting DcomLaunch/RpcSs).
- **Discovery (TA0007):** Evidence of Arp.txt and IpConfig.txt generation in post-breach artifacts.

5. Probable Incident Type

Data Staging and Exfiltration.

The evidence is highly indicative of an attacker who has gained access to a database (mysqld.exe) and is using native administrative tools (ROBOCOPY, ARP, IPCONFIG) for internal discovery and staging. A possible connection to external infrastructure was also observed in host-based artifacts (see §4); this has not yet been corroborated by SIEM network telemetry, so it is treated as unconfirmed pending further validation rather than as an established C2 channel.

6. Indicators of Compromise (IOCs)

Brute-force source IPs (block + hunt enterprise-wide)

- [BRUTEFORCE-IP-1] (24,536 attempts — primary)
- [BRUTEFORCE-IP-2] (3,693)
- [BRUTEFORCE-IP-3] (2,443)
- [BRUTEFORCE-IP-4] (747)
- [BRUTEFORCE-IP-5] (605)
- [BRUTEFORCE-IP-6] (456)
- [BRUTEFORCE-IP-7] (115)
- [BRUTEFORCE-IP-8] (21)
- [BRUTEFORCE-IP-9] (2)
- [BRUTEFORCE-IP-10] (2)
- [BRUTEFORCE-IP-11] (1)

Inbound RPC source IP

- [BRUTEFORCE-IP-12] -> TCP/135 (RpcEptMapper, PID 920)

Targeted accounts: administrator, root, admin, plus dictionary usernames (backup, support, manager, temp, office, server, demo, dell, pc, ...).

IOC sweep result: all brute-force source IPs were absent from every baseline artifact and present only in the post package, confirming onset within the comparison window.

7. Gaps

Security Logs: The security.txt file was not successfully ingested, limiting visibility into the specific account(s) used for lateral movement or the origin of the RDP sessions (seen in ActiveNetConnections.txt).

Command Line History: Full PowerShell script block logging is unavailable; while we see evidence of PowerShell execution, the exact commands executed remain partially obscured.

Cross-source correlation: The possible C2 connection identified in §4 has not been checked against firewall, proxy, or DNS logs, and does not appear in the DeviceNetworkEvents/NTANetAnalytics data reviewed in the main incident report. This is a gap, not a confirmation either way.

8. Recommended Immediate Actions

- Re-enable the Windows Firewall on all profiles and confirm via GPO enforcement.
- Restrict TCP/3389 and TCP/135 at the network perimeter; these should not be internet-reachable.
- Reset the administrator password and review for any reuse.
- Determine who/what disabled the firewall (correlate with change management, GPO history, and any available host telemetry).
- Block the listed IOC IPs and hunt for the same source IPs against other internet-facing hosts.
- Enable process-creation auditing (4688) with command-line logging to close the largest visibility gap going forward.
- **Validate the trafficmanager.net connection** against firewall/proxy/DNS logs and, if available, full packet capture, before escalating it as a confirmed C2 channel; update Section 4 above once corroborated or ruled out.